

BountyCharts — Owner Action List

Everything from the front-end audit that could **not** be completed autonomously. Generated 2026-08-29 · Oak and Main Developers LLC
· repo kevynsgrin-ally/BountyCharts

What was already shipped, so you can skip it: every WCAG AA contrast failure on both pages and both themes; the ticker disclosure (now visible *and* the accessible name); the social card and icon set; the publisher identity in structured data and the footer; links to the research; the dead data-theme CSS; five gate holes including total blindness to subdirectories; asset fingerprinting with enforcement. **40 tests, gate green.**

Everything below needs either an account you hold, a fact only you know, or a device this environment does not have. Items are ordered so the blocking ones come first.

Tag	Meaning
BLOCKING	Something is wrong or unsafe until this is done.
DECISION	Needs a fact or judgement only you have. Draft attached where one exists.
VERIFY	Already believed correct; needs confirming on a device or browser I cannot reach.

1 · Deployment topology — do these two first

☐ Check branch protection on main **BLOCKING**

This single setting decides whether audit finding **C3** is critical or merely untidy. With it, a red validate check stops a merge and the gate still holds at the merge boundary. Without it, the gate is advisory only.

Repo → Settings → Branches → add a rule for main → tick *Require status checks to pass before merging* → select **validate**.

☐ Decide which deploy path is authoritative **BLOCKING**

Measured: the GitHub Actions deploy job runs with its Cloudflare step skipped (no secrets), while Cloudflare Pages' own Git integration deploys the site independently. Across three consecutive pushes the Pages build began **4 s, 2 s and 4 s before the validate job even started** — so the deploy is not conditioned on the gate at all. Two paths exist; the one with the gate in front of it is the one not running.

Option A — keep Pages Git integration (recommended, it is what already works):

- Do the branch-protection step above; that becomes the real gate.
- Delete the deploy job from `.github/workflows/deploy.yml`.
- Rewrite `docs/deployment/cloudflare.md` steps 3–4, which currently describe a secrets-based path that is not the live one.

Option B — use the workflow instead: disconnect Git integration in the Pages project, then add both repo secrets:

```
Repo → Settings → Secrets and variables → Actions → New repository secret
CLOUDFLARE_API_TOKEN      (Account → Cloudflare Pages → Edit)
CLOUDFLARE_ACCOUNT_ID     820e7cee61fccc60d14c8e20bc686942
```

Do not do both. With Git integration active and the secrets added, both paths deploy the same project on every push and race each other.

2 · Domain and live verification

☐ Attach the custom domain and canonicalise www DECISION

The site currently serves only on *.pages.dev. Every canonical URL, the og:image URL and the sitemap already point at https://bountycharts.com/, so those are promises the DNS does not yet keep.

Pages project → Custom domains → add bountycharts.com and www.bountycharts.com. Then zone → Rules → Redirect Rules:

```
When:      Hostname equals www.bountycharts.com
Then:      Dynamic redirect, 301, preserve query string
Expression: concat("https://bountycharts.com", http.request.uri.path)
```

☐ Run five checks I could not — the live URL is egress-blocked here VERIFY

Audit finding **L5** is the only one still graded INFERRED, purely because of this. Paste and eyeball:

```
curl -sSI https://bountycharts.com/      | head -1      # expect HTTP/2 200
curl -sSI https://bountycharts.com/      | grep -i cache-control
curl -sSI https://bountycharts.com/nope  | head -1      # expect HTTP/2 404
curl -sSI https://www.bountycharts.com/  | head -3      # expect 301 to apex
curl -sSI https://bountycharts.com/      | grep -i set-cookie # expect nothing
```

The one to look at closely is line 2. _headers sets Cache-Control: max-age=0, must-revalidate on /*.html, but the landing page is served at /, which may not match that pattern — leaving the most cache-sensitive page on Cloudflare's default policy. If no must-revalidate comes back, add an explicit rule for / in site/_headers.

Line 5 settles the last open question: whether the edge sets cookies. If anything comes back, a privacy claim of "no cookies" cannot be made.

☐ Cross-browser and unfurl spot-checks VERIFY

Everything measured in this audit was Chromium-only. Three things are worth a 30-second look each in Safari and Firefox:

- **CSP.** script-src no longer allows 'unsafe-inline'. Zero violations in Chromium; confirm the console is clean elsewhere.
- **Favicon.** It is an inline SVG data URI. Confirm the tab icon shows a gold diamond, not a blank page.
- **Print.** With your OS in *dark* mode, print-preview the page. It must come out white with black text and the GitHub URL printed after the link.

Then paste the live URL into Slack, iMessage and X and confirm the social card renders wide, not as a small square.

3 · Facts and decisions only you can supply

☐ A contact address — or confirm there is none DECISION

The site has **no way to contact anyone and no way to hear about launch**. That is the largest remaining content gap. It was not fixed autonomously because `hello@bountycharts.com` does not exist, and publishing a dead address is worse than publishing none. A third-party signup form is also ruled out by the CSP (form-action 'self') and by the no-JavaScript rule the test suite enforces.

Cheapest working route: Cloudflare Email Routing on the zone you already own (free, gives a rotatable alias). Once the address resolves, this block is ready to paste after the Status section:

DRAFT — NEEDS A WORKING MX BEFORE IT SHIPS

```
<section>
  <h2>Hearing about launch</h2>
  <p class="tight">There is deliberately no signup form here. This site runs no
  scripts and calls no third party, and a form would end both. Two ways to hear
  when it ships:</p>
  <p class="tight"><a href="mailto:hello@bountycharts.com?
  subject=Notify%20me%20at%20launch">Email
  hello@bountycharts.com</a> – anything in the body. Your address is used to tell
  you about launch and nothing else: not sold, not shared, not added to any other
  list.</p>
  <p class="tight"><a href="https://github.com/kevynsgrin-ally/BountyCharts">Watch the
  repository</a> and choose Custom → Releases. Nothing reaches us that way at all.</p>
</section>
```

The privacy sentence is a commitment, so read it before shipping. As written it permits exactly one launch email and nothing further — if you later mail that group again, that is a list, and the sentence stops being true. Do not substitute a personal address: git authorship is not consent to publish a mailbox on a commercial page.

☐ Answer four questions, then the disclosures page can be written DECISION

A /disclosures page was specified and deliberately not built. Naming the company is not enough — the page has to make claims about conduct, and inventing those on a site whose entire pitch is verifiability would be worse than having no page. Your answers:

1. **Positions.** Do you or the LLC hold, trade, or speculate in any card or sealed product the site will cover? (A clean "no positions" statement is the single most valuable line on such a page — but only if true.)
2. **Affiliates.** Any existing relationship with TCGplayer or another retailer, signed or pending?
3. **Analytics.** Will anything be measured at launch? Cloudflare Web Analytics is cookieless and needs no consent banner; anything else changes the privacy copy.
4. **Cookies.** Settled by the curl in §2 above.

Timing matters on #2. docs/deployment/cloudflare.md records that an affiliate disclosure is legally required *before* the first affiliate link ships, not after. If a link is imminent, this page becomes blocking.

☐ **Confirm the darker brand gold** VERIFY

Shipped, because it was an accessibility defect rather than a taste question — but it is your brand, it is visible, and it is one commit to revert.

Token	Was	Now	Contrast	Used for
--gold	#9A6F1E	#966C1D	4.31 → 4.51	links, headings, wordmark
--gold-bright	#C9973F	#7A5716	2.52 → 6.27	link hover
--ink-faint	#8A93A1	#6D747F	2.97 → 4.51	labels, numerals
--ink-faint dark	#6B7482	#838C9A	3.69 → 5.14	same, dark theme

All are hue-preserving darkenings, not new hues. Hover now darkens rather than lightens, which is why --gold-bright moved so far. **Two standing rules:** never apply opacity to these three light-theme tokens — they clear the 4.5 threshold by about 0.01 and all three re-break at once — and recompute if --bg ever changes.

4 · Deferred by choice — reopen when the trigger fires

☐ **Replace the sample ticker figures with real Riftbound data** DECISION

The four figures are invented and now say so plainly, above the strip, in text that is also the accessible name. That is honest, but it is still a mock-up on a page whose thesis is that the data is the product. **Trigger:** the first real dataset.

☐ **A /method page** DECISION

The page promises "what the data says, *and where it came from*" and provides provenance for nothing. Specified in full in docs/content-and-image-spec-2026-08.md §5, not built — it would have to describe sourcing for a pipeline that does not exist yet. **Trigger:** the first real dataset, same as above.

☐ **Screen-reader pass on the new ticker caption** VERIFY

The caption is now both visible text and the accessible name via aria-labelledby, verified against Chromium's accessibility tree (33 words, naming all four cells and stating the figures are invented). No screen reader exists in this environment, so the announcement itself is spec-derived. A two-minute VoiceOver pass would close it.

Full detail: docs/frontend-audit-2026-08.md (21 findings) · docs/content-and-image-spec-2026-08.md (55 items) · docs/scorecard-2026-08.md (graded F, 59.0/100 on a Fortune 500 curve). Every number in this document was measured, not estimated.